Assignment 4 — Security, Resilience, and Intrusion Tolerance

Synthetic Kazakhstan University Research Server Incident

Talgatov Aibyn · Student ID 255308 · CSE-2505M · Instructor: Serek Azamat

Astana IT University | Fault Tolerance | Academic Year 2026–2027

Context note: All operational data in this assignment are synthetic educational data. They are designed to represent a realistic Kazakhstan/Astana university context and do not describe actual AITU infrastructure, incidents, or internal systems.

Incident dataset (synthetic)

Time	Event	Source	Severity
09:01	15 failed logins	10.20.4.15	Medium
09:03	21 failed logins	10.20.4.15	High
09:04	Successful login	10.20.4.15	High
09:07	320 files modified	10.20.4.15	Critical
09:08	CPU usage increased to 95%	Research-Server-01	High
09:10	1,200 files encrypted	Research-Server-01	Critical
09:12	Backup deletion attempt	Research-Server-01	Critical
09:13	Outbound connection to unknown IP	Research-Server-01	High
09:15	Database access spike	Research-Server-01	High
09:18	Antivirus disabled	Research-Server-01	Critical

Part A — Incident Analysis

Classify each event as reconnaissance, credential attack, privilege compromise, lateral movement, data destruction, persistence, exfiltration, or recovery attack.

Time	Event	Attack stage	Evidence	Risk
09:01	15 failed logins	reconnaissance	First contact from 10.20.4.15: 15 failed logins in the first logged burst (Medium severity). Consistent with probing which usernames exist and whether lockout is enforced. (ATT&CK: T1589 Gather Victim Identity Information (tactic: Reconnaissance)) Alternative reading: Start of the credential attack (T1110).	Medium
09:03	21 failed logins	credential attack	21 more failed logins from the same source 10.20.4.15; 36 cumulative failures logged between 09:01 and 09:03. (ATT&CK: T1110.001 Password Guessing (tactic: Credential Access))	High
09:04	Successful login	privilege compromise	Successful login from 10.20.4.15 immediately after 36 failed attempts (first failure logged 09:01): a guessed password became a valid session. (ATT&CK: T1078 Valid Accounts (tactic: Initial Access))	Critical
09:07	320 files modified	data destruction	320 files modified by the attacker session (source 10.20.4.15), 3 min after the successful login. (ATT&CK: T1486 Data Encrypted for Impact (tactic: Impact))	Critical

Time	Event	Attack stage	Evidence	Risk
09:08	CPU usage increased to 95%	data destruction	CPU at 95% on Research-Server-01, 1 min after the 320 file modifications and 2 min before 1,200 files are reported encrypted, so consistent with the encryption workload. (ATT&CK: T1486 Data Encrypted for Impact (tactic: Impact)) Alternative reading: 95% CPU alone is not specific on a research server (see Part E); resource hijacking (T1496) is less likely given the timing.	High
09:10	1,200 files encrypted	data destruction	1,200 files encrypted on Research-Server-01: direct loss of research data. (ATT&CK: T1486 Data Encrypted for Impact (tactic: Impact))	Critical
09:12	Backup deletion attempt	recovery attack	Backup deletion attempt on Research-Server-01, 2 min after encryption: an attack on the ability to recover. (ATT&CK: T1490 Inhibit System Recovery (tactic: Impact))	Critical
09:13	Outbound connection to unknown IP	exfiltration	Outbound connection from Research-Server-01 to an unknown IP. No transfer volume is logged, so exfiltration is assessed, not confirmed. (ATT&CK: T1041 Exfiltration Over C2 Channel (tactic: Exfiltration)) Alternative reading: A command-and-control channel only; double extortion is a hypothesis.	High
09:15	Database access spike	lateral movement	Database access spike from Research-Server-01: the compromised server is used as a pivot into the research database. Stated assumption: the database runs on a separate host. The queries may feed the outbound channel opened at 09:13. (ATT&CK: TA0008 Lateral Movement (assumed T1021 Remote Services, RS-01 → DB) + T1213 Data from Information Repositories (tactic: Collection)) Alternative reading: Exfiltration (collection).	High
09:18	Antivirus disabled	persistence	Antivirus disabled on Research-Server-01 at 09:18, 8 min after 1,200 files were encrypted. The dataset shows no AV alert during 09:07–09:10, so AV did not stop the encryption. Disabling it protects the attacker's continued access and hampers forensics. (ATT&CK: T1562.001 Impair Defenses: Disable or Modify Tools (tactic: Defense Evasion)) Alternative reading: Defense evasion; the spec vocabulary has no such stage, so it is classed as persistence.	Critical

Attack metrics: 36 failed logins in total; compromise after 3 min; encryption 6 min after compromise; 17 min from first contact to disabled antivirus. Risk is the assessed risk: it equals the dataset severity except 09:04, raised to Critical.

Part B — Risk Matrix

Risk = Likelihood × Impact. Use 1–4 Low, 5–9 Medium, 10–16 High, 17–25 Critical.

Threat	Likelihood	Impact	Risk Score	Priority
Credential compromise	5	4	20	Critical (#3)
Ransomware	5	5	25	Critical (#1)
Backup destruction	4	5	20	Critical (#2)
Data exfiltration	4	4	16	High (#4)
Privilege escalation	4	4	16	High (#5)

Scoring rules. Likelihood 5 = observed and succeeded in this incident; 4 = attempted or indirectly evidenced, with the outcome not logged. Impact 5 = loss of research data or of the ability to recover; 4 = serious but bounded (access or confidentiality). Ranking: score, then impact, then template order.

Threat	Likelihood rationale	Impact rationale	Sensitivity (L-1 / L / L+1)
Credential compromise	L5 (observed and succeeded): the 09:04 login succeeded after 36 guesses against password-only access.	I4: it grants entry to the research server but is not damage by itself.	High / Critical / Critical
Ransomware	L5 (observed and succeeded): 1,200 files were encrypted by 09:10.	I5: loss of research data and of the server's availability.	Critical / Critical / Critical
Backup destruction	L4 (attempted, outcome not logged): a deletion attempt at 09:12 against mutable backups, by an attacker who already held the rights it needs.	I5: it removes recoverability, turning a recoverable incident into permanent loss.	High / Critical / Critical
Data exfiltration	L4 (indirectly evidenced): an outbound connection to an unknown IP (09:13) and a database spike within 2 min (09:15), with no transfer volume logged.	I4: confidentiality loss of research and personal data with legal exposure, but no data destroyed.	High / High / Critical
Privilege escalation	L4 (indirectly evidenced): disabling antivirus and deleting backups both require administrative rights.	I4: an enabler of the other threats rather than damage by itself.	High / High / Critical

Implementation order. Risk rank and implementation order are separate decisions. MFA is deployed first because it removes the root cause (credential compromise); immutable backup second because it is the only control that still guarantees recovery when every preventive layer fails.

Part C — Resilient Security Architecture

Design a synthetic architecture containing MFA, network segmentation, immutable backup, monitoring, intrusion detection, secure failover, and a recovery environment.

Threat	Preventive control	Detection control	Recovery control
Credential attack	MFA on the bastion and VPN; per-source-IP lockout at 10 failures / 5 min (per IP, not per account, so attackers cannot lock researchers out); SSH unreachable from the user VLAN	SIEM alert at ≥10 failures / 5 min per source; "success after failures" correlation	Respond: block the source, revoke sessions. Recover: rotate the password, re-enrol MFA, review account activity
Ransomware	Segmentation; least-privilege write access to research shares; noexec on /tmp, /dev/shm and user-writable mounts plus application allow-listing (fapolicyd)	Canary-file write (immediate); FIM rate ≥100 changes/min AND extension/entropy change; CPU >90% and AI score used only as correlating signals	Respond: the hypervisor pauses RS-01 and moves it into the quarantine VLAN. Recover: restore data from the verified clean point onto RS-02, verify it in the clean room, then promote RS-02
Backup deletion	Pull-only vault, so production holds no vault credentials; zfs hold on vault snapshots; Object Lock compliance mode on the restic tier; just-in-time admin	Alert on any delete or retention-change API call, or a failed vault login	Recover: restore from the vault (tier 1, then the Object Lock tier); the offline Almaty copy is the last resort

Threat	Preventive control	Detection control	Recovery control
Data exfiltration	Egress default-deny allow-list proxy; least-privilege database roles	Suricata alert on a non-allow-listed destination and on volume anomalies; database query-rate anomaly	Respond: block the destination, revoke database credentials. Recover: scope the leaked records, report to KZ-CERT, and notify the authorised personal-data body and data subjects where Law No. 94-V and university policy require it
Privilege escalation	Just-in-time admin, no standing root, agent tamper protection	Alert on AV/EDR stop, a new admin account, or sudo outside the just-in-time window	Recover: rebuild the host from a golden image in the clean room; rotate all privileged credentials

Component inventory and the defence of each role:

Required component	Implementation	Zone	Role	Why this role
MFA	Multi-factor authentication: privacyIDEA TOTP/push via its PAM module on the SSH bastion and its FreeRADIUS plugin on the VPN; administrators additionally use FIDO2 OpenSSH keys (ed25519-sk); per-source-IP lockout at 10 failures / 5 min	Access zone	preventive	Preventive: stops a guessed password from becoming a session; it would have blocked the 09:04 login.
Network segmentation	Network segmentation: OPNsense firewall, VLANs, default-deny inter-zone rules, egress allow-list proxy, quarantine VLAN	All zone boundaries	preventive	Preventive by design: 10.20.4.15 reaches RS-01 only through the bastion and unknown egress (09:13) is denied. Its quarantine VLAN is reused for containment in recovery step 2.
Supporting (not one of the 7 required)	Privileged access management: Just-in-time sudo, separate admin accounts, no standing root, agent tamper protection	Access zone	preventive	Preventive: backup deletion (09:12) and disabling antivirus (09:18) need a just-in-time approval the attacker does not have.
Monitoring	Monitoring / SIEM: Wazuh SIEM + Prometheus/Grafana, correlation rules, active response	Security zone	detective	Detective: raises the 09:01 and 09:07 alerts. Its active response only orchestrates; the hypervisor, firewall and identity provider carry out the containment.
Intrusion detection	Intrusion detection: Suricata NIDS, Wazuh HIDS/FIM with canary files and an extension/entropy check, AI anomaly scorer	Security zone	detective	Detective: detects the encryption (09:07) and the unknown outbound connection (09:13).

Required component	Implementation	Zone	Role	Why this role
Immutable backup	Immutable backup: Tier 1 (fast restore): ZFS snapshots every 3 min on RS-01, pulled by the vault (zfs send -i | zfs receive, initiated from the vault) into its own pool and held with zfs hold; PostgreSQL WAL pulled continuously by pg_receivewal on the vault plus a nightly base backup. Tier 2 (WORM): restic copies every 15 min into a MinIO bucket with S3 Object Lock in compliance mode (30 days). Production holds no vault credentials	Backup vault (pull-only)	recovery	Recovery against ransomware: it does not stop encryption, but keeps clean restore points out of the attacker's reach. Tier 1 (worst-case loss 4 min) is protected by credential separation and zfs hold; tier 2 is write-once even for a vault administrator.
Secure failover	Secure failover: Research-Server-02: warm VM cloned from a golden image, holds no data and waits in the isolated recovery VLAN, out of reach of an attacker in the research VLAN; promoted after verification by re-tagging its vNIC into the research VLAN and switching the service VIP/DNS	Recovery zone (isolated VLAN; moved into the research VLAN on promotion)	recovery	Recovery: restores service on clean infrastructure within the RTO and never receives live-replicated (encrypted) data.
Recovery environment	Recovery environment: Isolated clean-room VLAN without internet access: restore, scan, verify	Recovery zone (isolated VLAN)	recovery	Recovery: restored data is verified in isolation before it returns to production.
Supporting (not one of the 7 required)	Virtualisation host (hypervisor): VM cluster running RS-01 and RS-02; its API lets Wazuh active response pause a VM, re-tag its vNIC into the quarantine VLAN and take memory + disk snapshots for evidence	Research zone (platform)	recovery	Response point, listed with recovery because the template has no respond column: containment and evidence capture happen here, since VLAN membership is set on the vNIC, not on the firewall.
Additional (Part E Q4, section 6)	Offline copy at a second Kazakhstan site: Logically air-gapped copy in Almaty (~970 km from Astana): transfer window opened daily from the Almaty side only, monthly rotation to disconnected media, separate admin domain, monthly restore drill; data-loss tier 24 h	Second site (Almaty)	recovery	Recovery: last resort that survives compromise of the vault's admin plane or loss of the Astana site.

A role is relative to the threat: Object Lock is preventive against backup deletion, while the backup as a whole is a recovery control against ransomware. Monitoring detects and orchestrates; the enforcement points (hypervisor, firewall, identity provider) carry out the response, which the template's three columns list under recovery as “Respond:”.

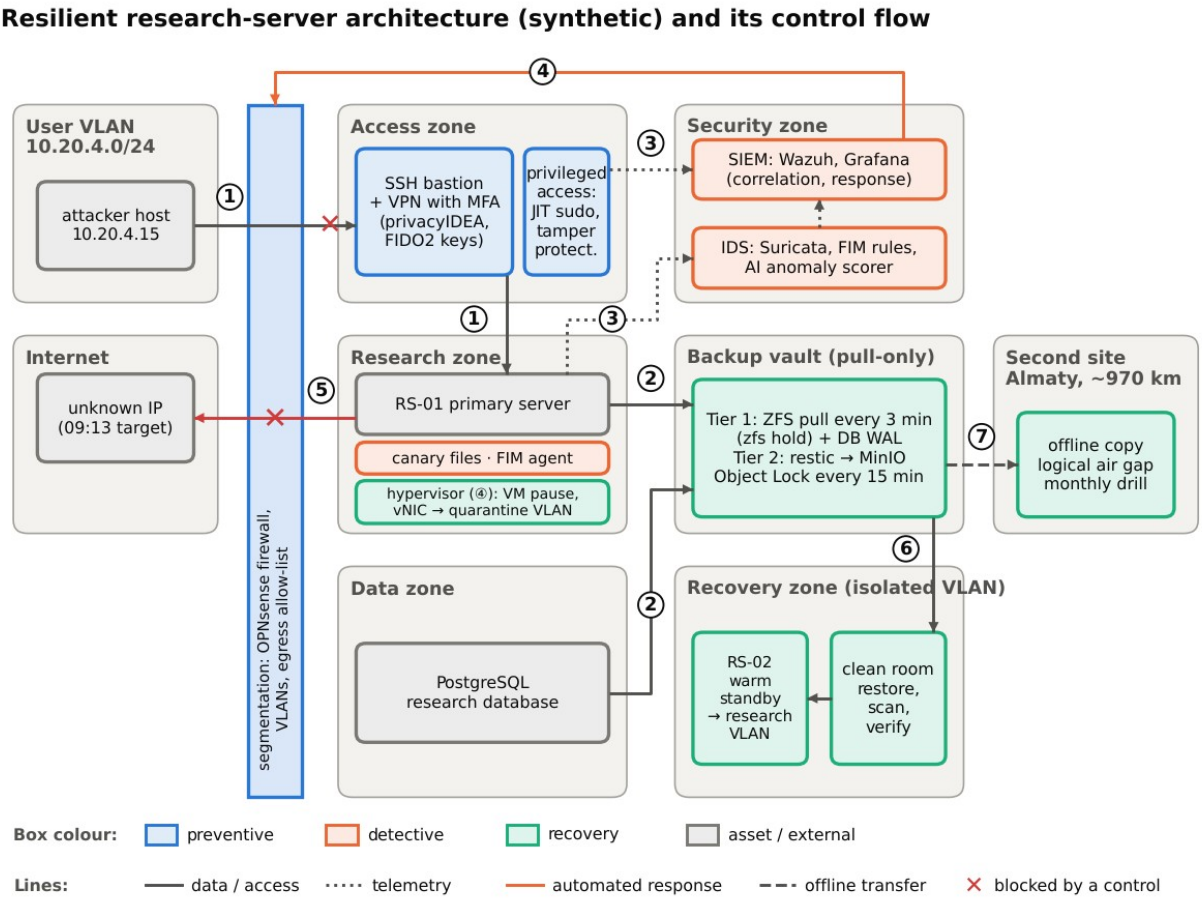


Figure 1. Resilient architecture and its numbered control flow (1)–(7).

How to read Figure 1

Figure 1 reads from left to right: the networks outside the perimeter, the segmentation boundary (blue bar), the production zones, the protection and recovery zones, and the second site. Box colour shows the control role: blue = preventive, orange = detective, green = recovery, grey = protected asset or external system. Lines: solid = access or data path (the arrowhead shows the direction of data), dotted = telemetry, orange = automated response, dashed = scheduled offline transfer, red ✕ = path blocked by a control. Numbers (1)–(7) mark the control flow.

Zones, from left to right:

- **User VLAN 10.20.4.0/24:** the campus network the attack came from (attacker host 10.20.4.15); it has no direct route to the research servers.
- **Internet:** the destination of the 09:13 outbound connection, reachable only through the egress allow-list.
- **Segmentation boundary:** OPNsense firewall and VLAN switching: default-deny between zones, egress allow-list, quarantine VLAN. Every arrow crossing it is an explicitly allowed or blocked path.
- **Access zone:** the SSH bastion and VPN with MFA, the only way into the research zone, and privileged access management (just-in-time sudo, tamper protection).
- **Research zone:** RS-01 with its canary files and FIM agent, running as a VM on the hypervisor that performs containment.
- **Data zone:** the PostgreSQL research database, whose WAL the vault pulls continuously.

- **Security zone:** the IDS (Suricata, FIM and canary rules, AI anomaly scorer) feeding the SIEM (Wazuh, Prometheus/Grafana), which correlates alerts and triggers the automated response.
- **Backup vault:** pull-only: tier 1 holds ZFS snapshots of RS-01 every 3 min (zfs hold), tier 2 restic copies every 15 min under Object Lock; production holds no vault credentials.
- **Recovery zone:** an isolated VLAN without internet: the clean room where restored data is scanned and verified, and the RS-02 warm standby, promoted into the research VLAN only after verification.
- **Second site (Almaty):** the offline copy, refreshed in a daily transfer window opened from the Almaty side.

Control flow:

- **(1) Access:** attacker host → boundary → SSH bastion. SSH reaches only the bastion, where MFA rejects the guessed password (red ✕, the 09:04 login); authorised users continue from the bastion to RS-01.
- **(2) Backup:** RS-01 and the database → vault. The vault initiates the pulls (snapshots every 3 min, WAL continuously), so RS-01 holds no credential the 09:12 deletion attempt could use.
- **(3) Telemetry:** bastion → SIEM and RS-01 (FIM, canary files) → IDS → SIEM. The failed logins raise the 09:01 alert and the mass file change raises the 09:07 alert.
- **(4) Response:** SIEM → enforcement points. Wazuh active response asks the hypervisor to pause RS-01 and re-tag its vNIC into the quarantine VLAN, and OPNsense applies a deny rule (isolated by 09:09).
- **(5) Egress control:** RS-01 → Internet. The connection to the unknown IP is denied at the boundary (red ✕, the 09:13 channel fails).
- **(6) Restore:** vault → clean room → RS-02. Data from the clean point is restored and verified in the isolated clean room, then RS-02 is promoted into the research VLAN (24 min estimate, 20 min on the critical path).
- **(7) Last-resort copy:** vault → Almaty. A daily transfer window copies the vault to the offline site (24 h tier).

Part D — Recovery Plan

Requirements: RPO ≤ 5 minutes; RTO ≤ 30 minutes.

Step	Action	Responsible component	Target time
1	Detect incident	ids + monitoring (canary / FIM + entropy rule, SIEM correlation, AI score)	1 min (by T+1)
2	Isolate affected system	hypervisor (VM pause, vNIC into the quarantine VLAN) + segmentation (OPNsense deny rule) + privacyIDEA/IdP (account lock), triggered by Wazuh active response	1 min (by T+2)
3	Preserve evidence	hypervisor (VM memory + disk snapshot) + monitoring (SIEM log export, SHA-256, WORM bucket)	4 min (by T+6, parallel with step 4)
4	Activate backup	immutable_backup (choose the clean point, clone it read-only from the vault ZFS pool into the clean room)	3 min (by T+5, parallel with step 3)
5	Restore services	failover (RS-02 warm VM from a golden image; data copied from the clean point; PostgreSQL PITR)	8 min (by T+13)
6	Verify integrity	recovery_env (hash manifest, YARA/AV scan, persistence check, DB consistency, canaries intact)	5 min (by T+18)
7	Return to production	failover + hypervisor (RS-02 vNIC into the research VLAN, VIP/DNS switch, rotated credentials)	2 min (by T+20)

RTO. Sequential estimate 24 min, critical path 20 min (steps 1→2→4→5→6→7; evidence preservation runs alongside steps 4–5 because restoring onto RS-02 does not touch RS-01), both ≤ RTO 30 min; slack 6 min.

RPO. Snapshots every 3 min (aligned to 09:00) + 1 min replication lag = 4 min worst-case data loss ≤ RPO 5 min. Clean-point rule, decided in step 4 before the restore: 09:06 (last snapshot before the first malicious change at

09:07) if its diff against 09:03 is clean, otherwise 09:03 (before attacker access at 09:04): 1 or 4 min of data loss. The fallback's loss grows with the attacker's dwell time.

- **Step 1.** Canary write or FIM rate + entropy rule fires on the 09:07 mass modification; Wazuh correlates it with the 09:01 brute-force alert and the AI score.
- **Step 2.** Automated: the hypervisor pauses RS-01 (memory preserved) and re-tags its vNIC into the quarantine VLAN, OPNsense blocks 10.20.4.15 and RS-01's address, and privacyIDEA locks the compromised account.
- **Step 3.** Snapshot the paused VM's memory and disk, export SIEM/FIM/Suricata logs, hash everything with SHA-256 and store it in a write-once bucket.
- **Step 4.** Choose the clean point before restoring: diff the 09:06 snapshot against 09:03 (new executables, authorized_keys or cron entries, changed canaries). Use 09:06 if the diff is clean, otherwise 09:03 (before attacker access), and clone it read-only into the recovery environment.
- **Step 5.** Copy data from the clean point onto RS-02 (assumption: ≤200 GB over 10 GbE ≈ 3 min) and run PostgreSQL point-in-time recovery to the clean point (≤5 min) unless the DB audit log shows an earlier malicious write.
- **Step 6.** Compare file hashes with the clean-point manifest, scan with YARA/AV, confirm no new executables, authorized_keys or cron entries, run DB consistency checks and confirm the canary files are intact.
- **Step 7.** Promote RS-02: re-tag its vNIC from the recovery VLAN into the research VLAN, switch the service VIP/DNS, rotate credentials and keep heightened monitoring; only after the evidence is preserved and integrity is verified.

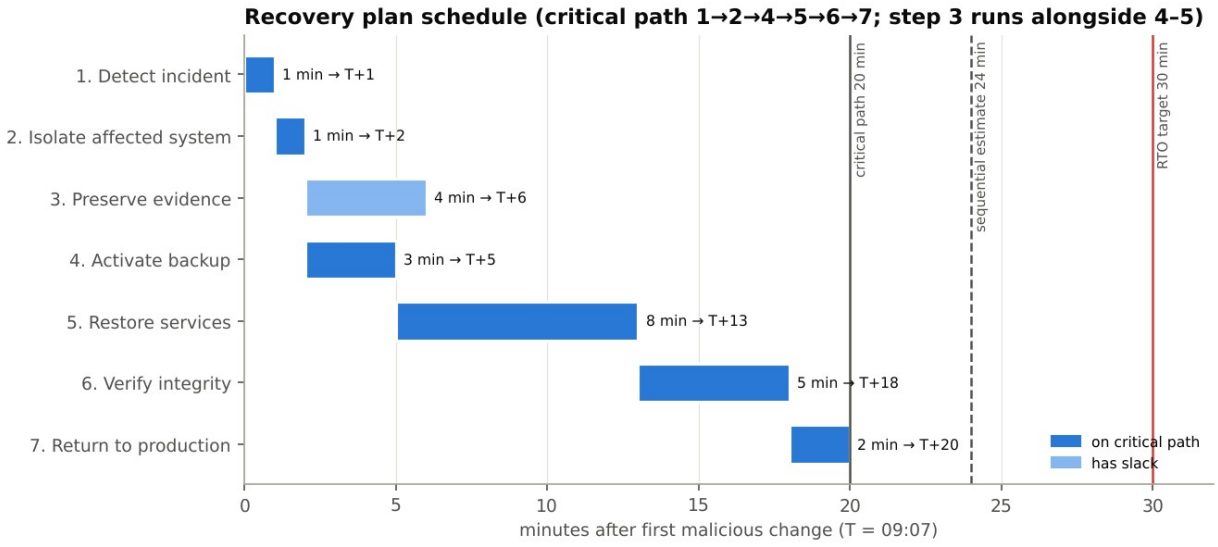


Figure 2. Recovery schedule against the 30-minute RTO.

Part E — AI-Assisted Detection

Event	Normal score	Observed score	Delta	Anomaly (score ≥ 0.75)
Login failures	0.10	0.81	0.71	yes
File modifications	0.12	0.96	0.84	yes
CPU usage	0.20	0.88	0.68	yes
Outbound traffic	0.15	0.79	0.64	yes
Database requests	0.18	0.91	0.73	yes

1. Calculate the number and rate of detected anomalies. 5 of 5 signals score at or above 0.75, so 5 anomalies are detected and the detection rate is 5/5 = 100%.

2. Identify the highest-priority event. File modifications: observed 0.96 against a normal 0.12 (Δ 0.84), the highest score and the largest deviation. It marks the start of data destruction at 09:07, so it is the signal that should trigger isolation.

3. Explain why AI-assisted detection should complement, not replace, deterministic security and recovery controls. AI scores are probabilistic: they produce false positives and false negatives, and outbound traffic clears the threshold by only 0.04, so a threshold of 0.80 would miss the exfiltration channel. Research servers legitimately run at 95% CPU during simulations, so the CPU signal alone has low specificity. The model only detects: it cannot stop the backup deletion or restore data. The attacker disabled antivirus at 09:18, and an AI agent on the same host can be tampered with the same way. Baselines drift with semester and exam load. Deterministic controls (MFA, Object Lock, egress default-deny) work even when detection fails and are auditable, so AI should prioritise and correlate alerts on top of them.

4. Recommend one additional resilience mechanism appropriate for a Kazakhstan university research environment. An offline, logically air-gapped copy of the backup vault at a second Kazakhstan site (Almaty, ~970 km from Astana), refreshed in a daily transfer window and checked by a monthly restore drill (see section 6).

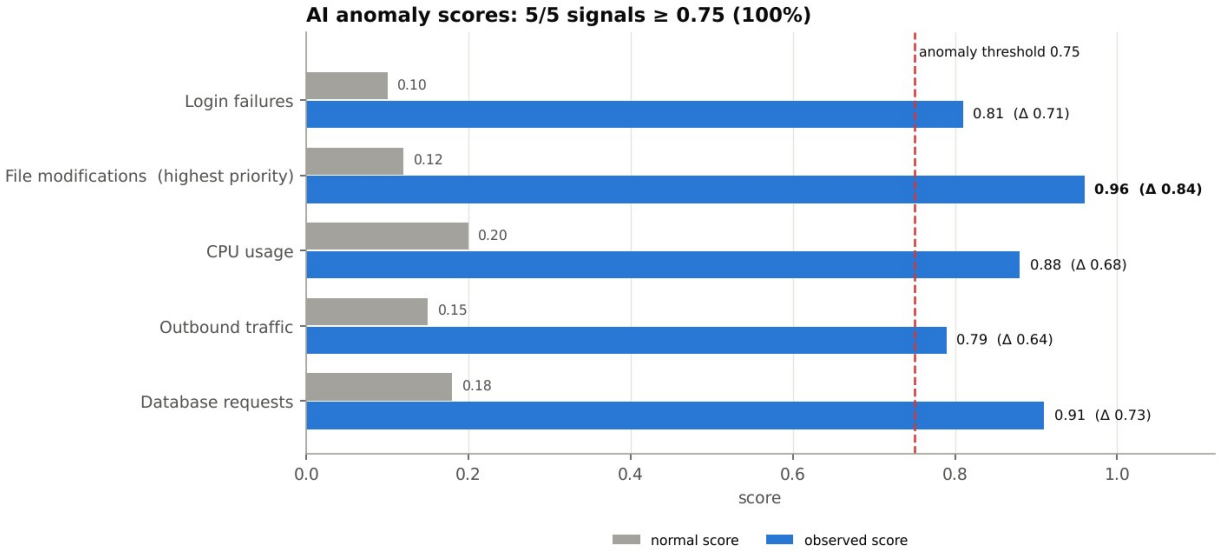


Figure 3. Normal vs observed AI anomaly scores with the 0.75 threshold.

Threshold sensitivity: number of signals flagged at each threshold.

Threshold	Signals flagged
0.75	5
0.80	4
0.85	3
0.90	2
0.95	1

Before/After Simulation

The same ten events are replayed against the as-is system and against the proposed architecture (src/fault4/simulation.py, configs/scenarios.json). Assumptions:

- The replay is deterministic and non-adaptive: the attacker follows the dataset timing.
- Rows are per-minute aggregates, so 320 files modified at 09:07 means 320 changes/min; they are assumed to include encrypted-extension/entropy changes, so the combined FIM rule fires. The 100/min value is a placeholder to be tuned on at least one week of real FIM data.
- The 320 modified files are part of the 1,200 encrypted ones (files impacted = maximum, not sum).
- In the baseline, the deletion attempt on mutable backups succeeds.
- Assume-breach scenarios disable every access-zone control (lockout, MFA via a stolen session token, response to the 09:01 alert) to test whether detection plus immutable recovery alone bound the damage. Part D assumes isolation by T+2; manual isolation at T+4 delays the whole recovery by 2 minutes.
- In the hardened scenario a low-and-slow guesser (≤9 tries per 5 min) would evade lockout; MFA, not lockout, is the control that robustly stops the 09:04 login.

Metric	Baseline (as-is)	Hardened	Assume breach, automated isolation	Assume breach, manual isolation
Attacker gains a session	yes	no	yes	yes
Attack stopped / contained at	never	09:01	09:09	09:11
First automated detection	none	09:01	09:01	09:01
Files impacted	1,200	0	320	1,200
Backups destroyed	yes	no	no	no
Exfiltration channel open	yes	no	no	no
Antivirus disabled	yes	no	no	no
Data loss, min	unbounded (backups lost)	none	1 (fallback 4)	1 (fallback 4)
Recovery time, min	not achievable	no recovery needed	24	26

With automated isolation the impact drops from 1,200 to 320 files (73.3% fewer). With manual isolation all 1,200 files are hit, but the data still comes back within RPO and RTO because the backups were immutable: automation limits the blast radius, immutability guarantees recoverability.

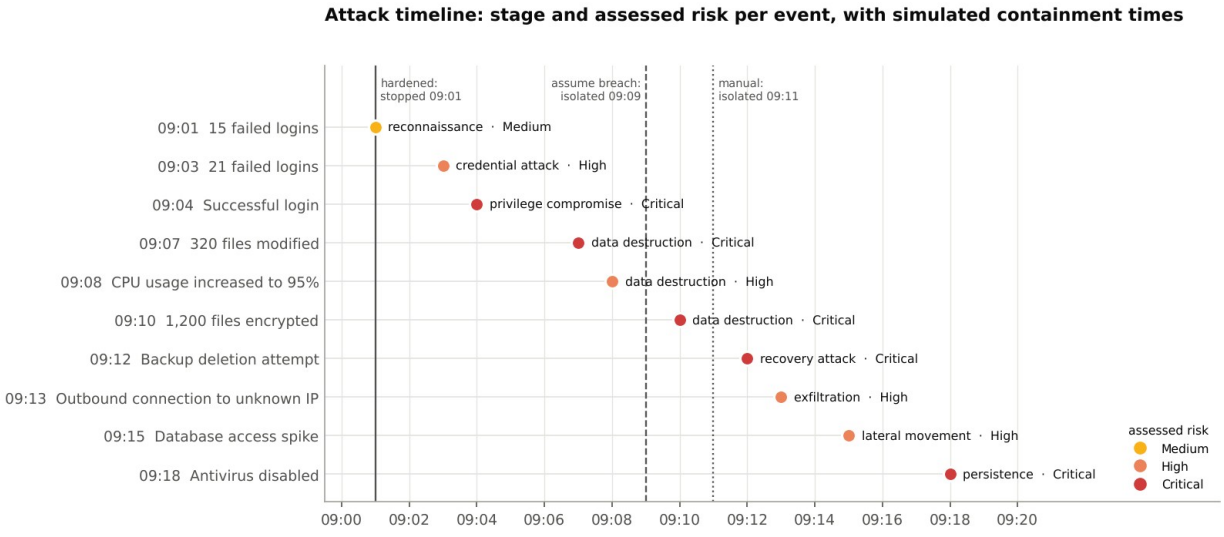


Figure 4. Attack timeline with simulated containment times.

Conclusion

The synthetic incident went from first contact to disabled antivirus in 17 minutes with no automated response, encrypting 1,200 files and attacking the backups. The proposed architecture answers each stage with a preventive, a detective and a recovery control. In the replay, the lockout's source block stops the attack at 09:01 (MFA would also reject the 09:04 login); if the access layer is bypassed, automated isolation at 09:09 limits the damage to 320 files (73.3% fewer), immutable backups survive the 09:12 deletion attempt and egress filtering blocks the 09:13 channel. Recovery is estimated at 24 min (20 min on the critical path) against a 30-minute RTO, with at most 4 min of data loss against a 5-minute RPO. AI scoring flags all signals (100%) and ranks file modifications first, but the 0.04 margin on outbound traffic shows why it must complement, not replace, deterministic controls.

STUDENT TECHNICAL WORK REPORT / SUBMISSION RECORD

Assignment 4 — Security, Resilience, and Intrusion Tolerance

Purpose: This form is a formal submission record. The student must complete every applicable field and attach evidence of their own work. Short generic explanations are not sufficient.

1. Student and Submission Information

Required field	Student entry
Student full name	Talgatov Aibyn
Student ID	255308
Group / cohort	CSE-2505M
Instructor	Serek Azamat
Date of submission	____ / ____ / _____
Individual variant / task code assigned by instructor	_____
Git repository / project link	https://github.com/a169n/fault_4
Attached code / file names	src/fault4/*.py, tests/*.py, data/*.csv, configs/scenarios.json, outputs/results.json, outputs/run_log.txt, outputs/test_log.txt, outputs/figures/*.png, run_all.sh

2. Work Period and Task Record

Item	Student entry
Work start date/time	2026-10-31 10:43 (UTC+5, Astana)
Work completion date/time	2026-10-31 11:56 (UTC+5, Astana)
Main task completed	Assignment 4 Parts A–E (incident classification, risk matrix, resilient architecture, recovery plan, AI anomaly analysis) plus a before/after attack simulation
Tools / technologies used	Python 3.9+, matplotlib 3.9.4, python-docx 1.1.2, pytest 8.3.5, Git/GitHub, LibreOffice (PDF export), macOS
Main technical output produced	Reproducible analysis pipeline (python -m fault4 all), results.json, 5 figures, 4-scenario simulation, this report

3. Report Structure to Complete

For each section below, write the requested evidence in your own words. Include calculations, diagrams, code references, screenshots, logs, or experimental evidence where applicable.

1. Incident Analysis

Classify every incident event into an attack stage, provide evidence from the synthetic dataset, and assess risk.

Required content	Student response / evidence
Summary	All 10 events are classified. The attack moves from probing at 09:01 through 36 failed logins to a successful login at 09:04, encryption of 1,200 files by 09:10, a backup deletion attempt (09:12), an outbound channel (09:13), database access (09:15) and disabling of antivirus (09:18). The intrusion lasted 17 minutes and nothing reacted automatically: antivirus was running during the encryption and did not stop it.
Evidence / calculation / artifact reference	Part A table; code src/fault4/incident.py (classify_events, attack_metrics); outputs/results.json → incident; Figure 4. Metrics: 36 failed logins, compromise after 3 min, encryption 6 min after compromise, 17 min in total. Every row cites the dataset value and an ATT&CK reference.

Required content	Student response / evidence
Student-specific decision or observation	09:15 is classed as lateral movement rather than exfiltration: the spike shows the compromised server used as a pivot into the research database, which I assume runs on a separate host. 09:04 is raised from High to Critical because every later event depends on that login. Four classifications are interpretive (09:01, 09:08, 09:15, 09:18); each states its alternative reading in the Part A table.

2. Risk Matrix

Assign likelihood and impact, calculate Risk = Likelihood × Impact, and justify the resulting priority.

Required content	Student response / evidence
Summary	Ransomware ranks first (5 × 5 = 25), followed by backup destruction and credential compromise (both 20, Critical); data exfiltration and privilege escalation score 16 (High). Ties are broken by impact, then template order.
Evidence / calculation / artifact reference	Ransomware 5 × 5 = 25 (Critical); Backup destruction 4 × 5 = 20 (Critical); Credential compromise 5 × 4 = 20 (Critical); Data exfiltration 4 × 4 = 16 (High); Privilege escalation 4 × 4 = 16 (High). Code src/fault4/risk.py; Figure 5. Sensitivity (likelihood ±1): only ransomware stays Critical at L−1; data exfiltration and privilege escalation become Critical at L+1.
Student-specific decision or observation	One likelihood rule for every threat: 5 = observed and succeeded, 4 = attempted or indirectly evidenced. Implementation order is separate from risk rank: MFA first because it removes the root cause, then immutable backup because it is the only control that still guarantees recovery when prevention fails.

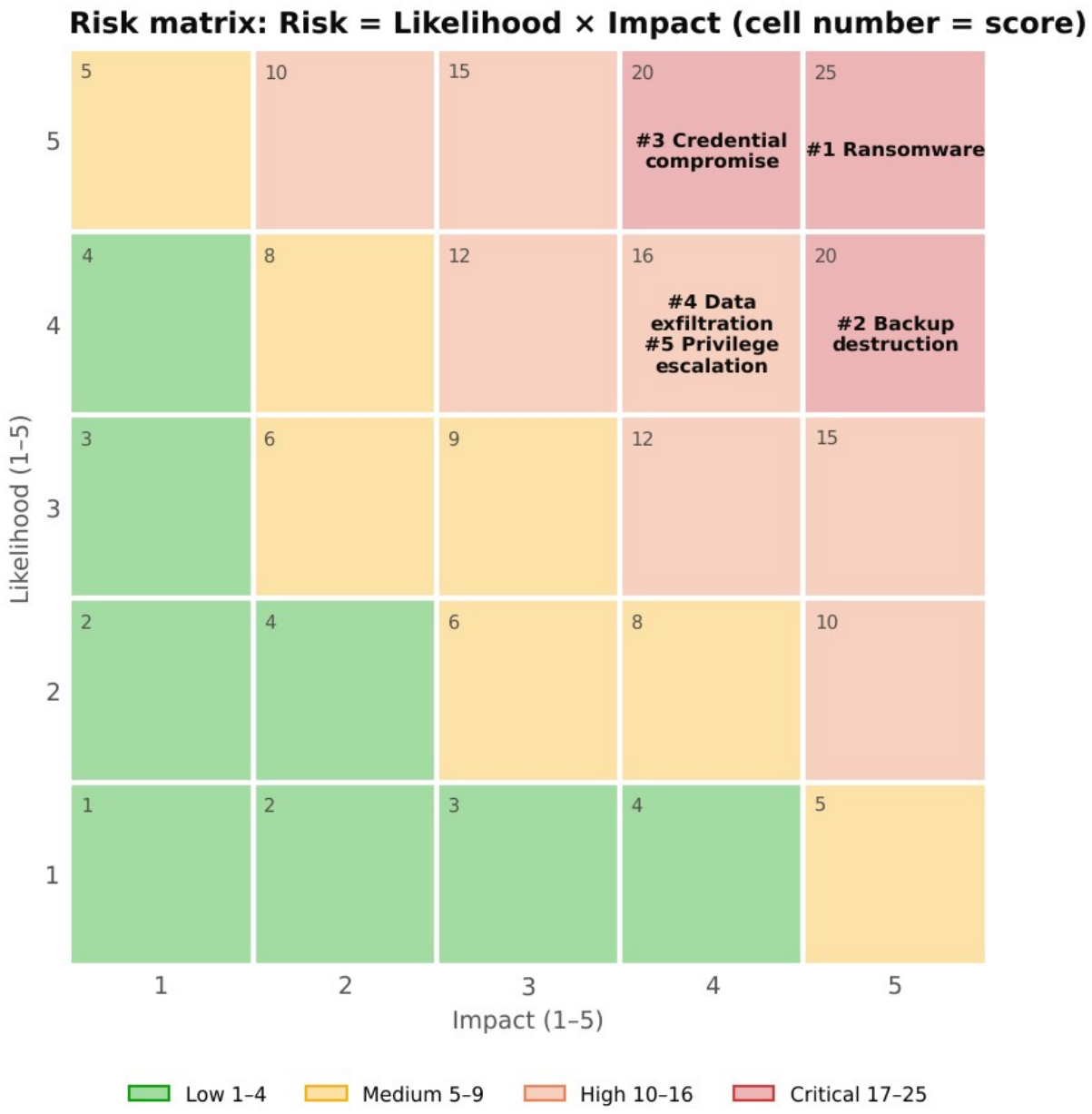


Figure 5. Risk matrix (Risk = Likelihood × Impact).

3. Resilient Security Architecture

Design the required architecture containing MFA, segmentation, immutable backup, monitoring, intrusion detection, secure failover, and recovery environment.

Required content	Student response / evidence
Summary	The research server sits behind an OPNsense firewall with separate access, research, data, security, backup and recovery zones. All seven required components are present (MFA, segmentation, immutable backup, monitoring, intrusion detection, secure failover to RS-02, isolated recovery environment), plus an offline copy in Almaty.

Required content	Student response / evidence
Evidence / calculation / artifact reference	Part C table and component inventory; Figure 1 with control flow (1)–(7); src/fault4/controls.py, where coverage_gaps() returns an empty list: every required component exists, every threat has preventive, detective and recovery controls, and every component is used.
Student-specific decision or observation	Failover is snapshot-based, not live replication: live replication would have copied the 1,200 encrypted files to the standby. RS-02 waits in the isolated recovery VLAN, out of the attacker's reach, and is moved into the research VLAN only after verification. Containment is done by the hypervisor (quarantine VLAN), not the firewall, and is marked “Respond:” in the recovery column.

4. Recovery Plan

Complete the seven-step recovery plan and show how your target RPO ≤ 5 minutes and RTO ≤ 30 minutes are addressed.

Required content	Student response / evidence
Summary	Seven steps timed from the first malicious change (T = 09:07): 1+1+4+3+8+5+2 = 24 min sequentially, 20 min on the critical path 1→2→4→5→6→7 (evidence preservation runs alongside steps 4–5, because restoring onto RS-02 does not touch RS-01); both meet the 30-minute RTO. Worst-case data loss is 3 + 1 = 4 min, within the 5-minute RPO.
Evidence / calculation / artifact reference	Part D table; src/fault4/recovery.py (recovery_check); Figure 2. Snapshots every 3 min aligned to 09:00 with 1 min replication lag. Clean points: 09:06 (last snapshot before 09:07) loses 1 min; fallback 09:03 (before attacker access at 09:04) loses 4 min.
Student-specific decision or observation	I chose a 3-minute interval because 5 + 1 = 6 minutes of loss would breach the RPO once the replication lag is counted. The clean point is chosen in step 4, before the restore: the attacker was present from 09:04, so 09:06 is used only if its diff against 09:03 is clean. Deciding first keeps both choices inside the RTO.

5. AI-Assisted Detection

Calculate the anomaly count/rate, identify the highest-priority event, and explain the role and limitations of AI-assisted detection.

Required content	Student response / evidence
Summary	All signals are at or above 0.75: 5/5 = 100%. File modifications is the highest-priority event (0.96, Δ 0.84) and coincides with the data-destruction stage. AI scoring complements, but cannot replace, deterministic controls.
Evidence / calculation / artifact reference	Deltas: Login failures 0.71, File modifications 0.84, CPU usage 0.68, Outbound traffic 0.64, Database requests 0.73. Threshold sweep 0.75/0.80/0.85/0.90/0.95 → 5/4/3/2/1 anomalies. Code src/fault4/anomaly.py; Figure 3.
Student-specific decision or observation	Rank by absolute deviation plus kill-chain stage, not ratio: the ratio would pick login failures (8.10× vs 8.00×) only because its baseline is small. Keep the threshold at 0.75: at 0.80 outbound traffic (0.79, margin 0.04), the exfiltration indicator, would be missed.

6. Additional Resilience Recommendation

Recommend one additional resilience mechanism appropriate for the synthetic Kazakhstan university research environment and justify it.

Required content	Student response / evidence
Summary	Recommended mechanism: an offline, logically air-gapped copy of the backup vault at a second Kazakhstan site (Almaty), refreshed in a daily transfer window opened from the Almaty side, with monthly rotation to disconnected media and a monthly restore drill.

Required content	Student response / evidence
Evidence / calculation / artifact reference	Tier comparison: vault tier 1 (ZFS, 4 min worst-case loss) and tier 2 (Object Lock, 15 min) share the Astana site and the vault's admin domain; the Almaty copy (~970 km away) is a 24 h tier that survives compromise of the vault's admin plane or loss of the site. Modelled as offline_copy in src/fault4/controls.py and flow (7) in Figure 1.
Student-specific decision or observation	An in-country second site instead of a foreign cloud: Law of the Republic of Kazakhstan No. 94-V "On Personal Data and Their Protection", Article 12, requires databases with personal data to be kept on the territory of Kazakhstan, and research datasets may contain participants' personal data.

4. Individual Work and Anti-Plagiarism Record

Because the assignment uses a common educational scenario and dataset, the submitted report must contain verifiable evidence of the individual student's work. Copying another student's wording, calculations, architecture, code, logs, screenshots, or conclusions is not acceptable.

- Use your own threat/control mapping rather than copying another student's table wording.
- Tie each risk score to your own justification.
- Provide a unique architecture diagram and explain its control flow.
- Record the exact source file/version used for your analysis.
- Be prepared to defend why one control is preventive, detective, or recovery-oriented.

Individual evidence	Student entry
My unique technical decision	3-minute immutable snapshots chosen by counting the 1-minute replication lag (3 + 1 = 4 ≤ 5, while 5 + 1 = 6 would breach the RPO), a two-clean-point rule decided before the restore (09:06 if its diff against 09:03 is clean, otherwise 09:03, before attacker access), and a standby kept in the isolated recovery VLAN instead of a live replica.
My own implementation / calculation evidence	Python package fault4 with an automated pytest suite (outputs/test_log.txt). Four-scenario replay: the baseline loses 1,200 files and the backups; the hardened design stops the attack at 09:01; with the access layer bypassed, automated isolation limits damage to 320 files (73.3% fewer); manual isolation loses 1,200 files but still recovers, 2 min later. Estimated recovery time 24 min (critical path 20 min), worst-case data loss 4 min.
Exact file, code, commit, notebook, or log reference	https://github.com/a169n/fault_4: code at commit fd466d9 (outputs and this report are committed in the next commit on main); fault4 v1.0.0. Dataset transcribed from Assignment_4_AITU_Security_Resilience_Report_Template.pdf (SHA-256 a1c8c43e799a9f2f…): incident table p.1, Part E table p.2, into data/incident_events.csv (SHA-256 b4b3b59765035a9f…) and data/anomaly_scores.csv (SHA-256 d50d601682cda1f6…). Outputs: outputs/results.json, outputs/run_log.txt.
One problem I personally encountered and how I solved it	The ratio and the absolute deviation disagreed on the top anomaly (login failures 8.10× vs file modifications Δ 0.84). I ranked on the deviation plus the kill-chain stage, because ratios inflate signals with a small baseline, and reported both in Part E.
One limitation of my own solution	One synthetic incident replayed deterministically by a non-adaptive attacker; the FIM threshold (100 changes/min) was chosen knowing this incident, so it may overfit; no false-positive rate was measured; recovery-step durations are estimates, not measured drills; the 4-min data-loss bound holds for the preferred clean point, while the fallback's loss grows with the attacker's dwell time before the first malicious change (here 3 min).

5. Evidence Checklist

☒ **Completed required tables and calculations** — Parts A–E tables; outputs/results.json

☒ **Architecture / RBD / FTA / security diagram where applicable** — outputs/figures/architecture.png (Figure 1)

☒ **Source code or configuration files where applicable** — src/fault4/*.py, configs/scenarios.json

☒ **Execution logs / experiment results where applicable** — outputs/run_log.txt, outputs/test_log.txt

☒ **Screenshots or other reproducible evidence where applicable** — ./run_all.sh reproduces outputs/results.json byte-identically (SHA-256 values in the Appendix); outputs/figures/*.png

☒ **Links to code, datasets, notebooks, or artifacts** — https://github.com/a169n/fault_4; data/*.csv

☒ **Before/after comparison where applicable** — Before/after simulation section (4 scenarios)

☒ **Final technical conclusion** — Conclusion section

6. Student Declaration

I confirm that this report describes my own work. I have not copied another student's report, code, calculations, diagrams, logs, screenshots, or conclusions. Any external source or reused material has been identified. I understand that I may be asked to reproduce or explain any part of this submission during the oral defense.

Role	Name	Signature	Date
Student / Executor	Talgatov Aibyn	_____	_____
Instructor / Accepted by	Serek Azamat	_____	_____

7. Instructor Acceptance Record

Check	Status / comment
Report structure completed	☐ Yes ☐ No Comment: _____
Evidence is sufficient	☐ Yes ☐ No Comment: _____
Individual contribution is identifiable	☐ Yes ☐ No Comment: _____
Oral defense completed	☐ Yes ☐ No Comment: _____
Final status	☐ Accepted ☐ Revision required

References and external sources

1. MITRE ATT&CK Enterprise matrix, https://attack.mitre.org — techniques and tactics T1589, T1110.001, T1078, T1486, T1490, T1041, T1213, T1562.001, TA0008 (accessed 31 October 2026).
2. Law of the Republic of Kazakhstan No. 94-V of 21 May 2013 “On Personal Data and Their Protection”, Article 12, https://adilet.zan.kz/eng/docs/Z1300000094 (accessed 31 October 2026).
3. NIST SP 800-61 Rev. 3 (April 2025), Incident Response Recommendations and Considerations for Cybersecurity Risk Management, https://doi.org/10.6028/NIST.SP.800-61r3 (basis for separating Respond from Recover).
4. Vendor documentation: privacyIDEA, OPNsense, Wazuh, Suricata, MinIO Object Lock, OpenZFS send/receive, PostgreSQL continuous archiving and point-in-time recovery, fapolicyd.
5. Assignment specification: Assignment_4_AITU_Security_Resilience_Report_Template.pdf (SHA-256 a1c8c43e799a9f2f31d9b5200f772ab99b37054ad648dbaa6d4770475675e35a).
6. AI assistance: analysis code and draft text were prepared with the help of an AI coding assistant (Claude, Anthropic); the student reviewed, ran and verified all results.

Appendix — Reproducibility

fault4 v1.0.0, commit fd466d9. Commands:

- python3 -m venv .venv
- .venv/bin/pip install -r requirements.txt
- ./run_all.sh # tests, analysis, figures, report, PDF
- PYTHONPATH=src .venv/bin/python -m fault4 analyze # results.json and run_log.txt only

File	SHA-256
Assignment_4_AITU_Security_Resilience_Report_Template.pdf	a1c8c43e799a9f2f31d9b5200f772ab99b37054ad648dbaa6d4770475675e35a
anomaly_scores.csv	d50d601682cda1f6bd3ef5381520f215989eea1b3f14402f44bb85f42d272a0d
incident_events.csv	b4b3b59765035a9fd853bc643ded10d73fa8a3284bb49c4e34ccad0842d2ed91
scenarios.json	65637ad3a1ba280d3316c94c054c59a757c1a5dd610aba59947064ceeefacd30